



Secure By Design

TRUSTED THROUGH COMPLIANCE

MP@SOLSTICELLC.IO



The Problem

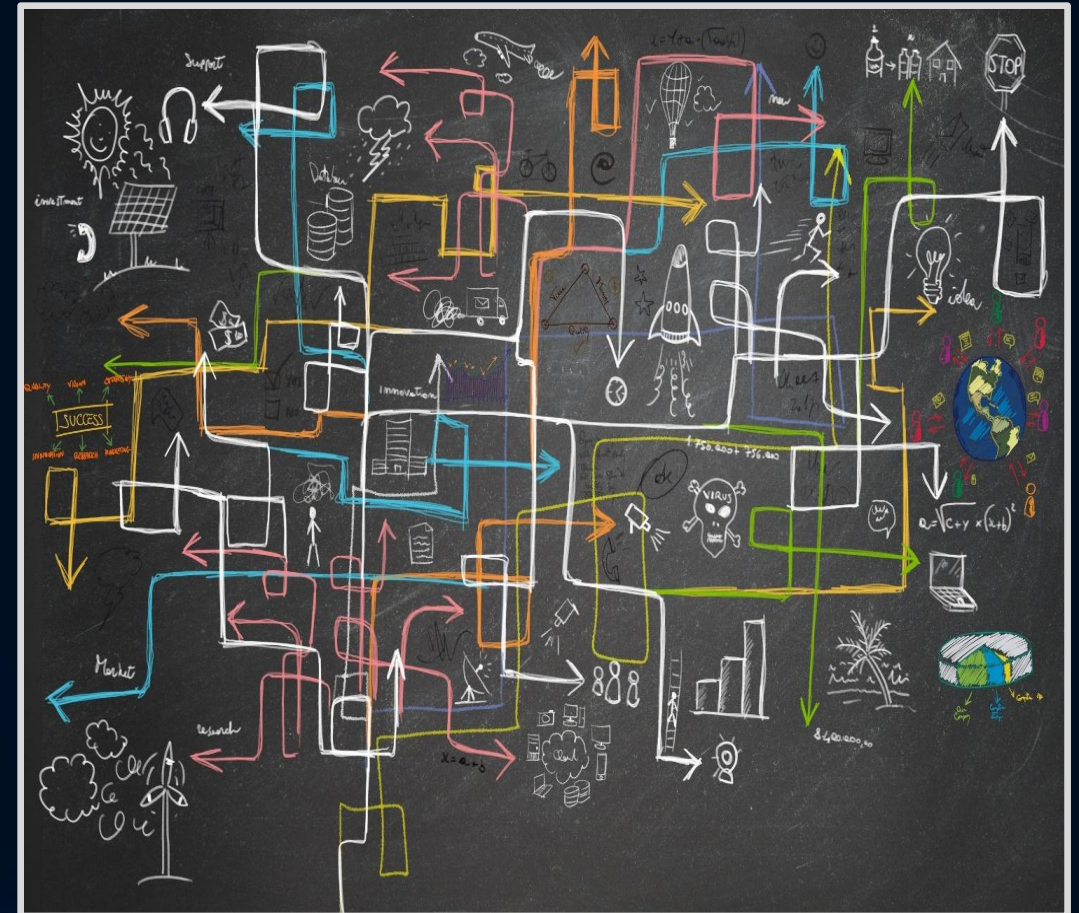
Complexity

- Where do you find the definitive guidebook for security?
- How do you understand the breadth and depth of the digital resources you're protecting?
- How do we understand technical vs GRC?

Audit Ready and Operationally Fragile

- Paperwork says one thing, infrastructure tells a different story
- Creates a schism between "technical" and "non-technical" security teams

Actual Drawing of a Company's Security Program



This Photo by Unknown Author is licensed under CC BY-NC



What Are We Even Doing Here?



The Most Secure Computer

Defending a Network?

Breach, Ransomware, Data Exfiltration, System Compromise

Defending Our Processes?

BEC Wire Fraud, Social Engineering, Process Failures

Trying Not to Get Sued?

Contractual Requirements, Regulatory Penalties, Loss Of Trust

Trying not to get Fined or Worse?

Regulations, Privacy Laws?



Defining Security

Goal

Reduce Probability of a Material Impact of a Cybersecurity Incident

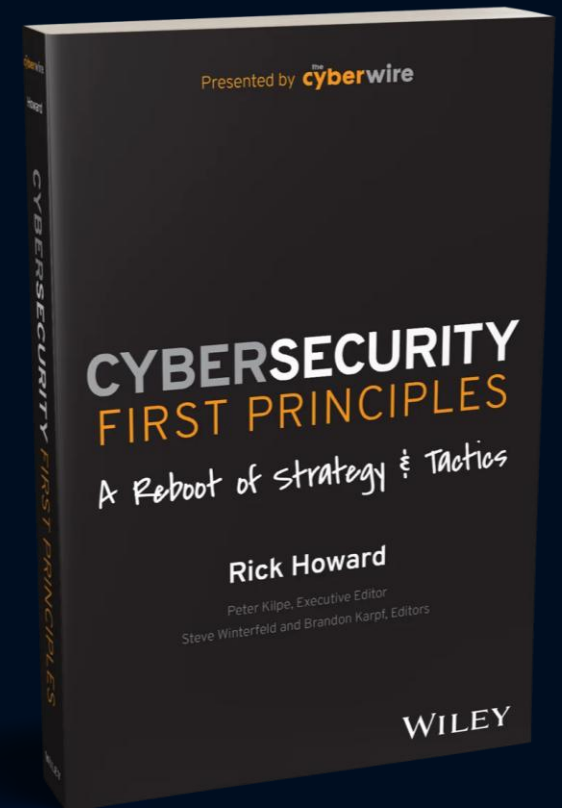
Definition

Security is Risk Management

No system is ever completely safe. We must make trade-off decisions

Guiding Principles

Security Is Not the End. It Enables People to Do Their Job's Securely





-
- A cartoon illustration of a man in a suit sitting at a desk with a laptop. He has a thoughtful expression, resting his chin on his hand. Above him is a large blue thought bubble filled with various icons representing digital concepts like clouds, locks, envelopes, gears, lightbulbs, and documents, symbolizing complex IT or cybersecurity issues.



Bridging the Gap



Have You Ever Met An Engineer
Who Wasn't Doing The Jobs of
Three People?

Heroics Can Save The Day But
Burn People Out

The System Matters



MEETING



*A Detour Into My
Theory of
Meetings*



A Quick Definition

	Security Compliance Framework	Security Baseline
Definition	Structured <u>system of policies, procedures, controls, and documentation</u> that helps organizations meet legal, regulatory, and industry-specific standards while <u>managing operational and reputational risks</u>	Standard set of <u>security settings, configuration, and controls</u> established for each type of computer or network component that helps in reducing vulnerabilities, thus <u>lowering the risk of security incident</u>
Primary Purpose	Manage risk and satisfy auditors/regulators	Configure your devices, servers, cloud, and security assets
Focus	Process, policies, and overarching risk management.	Technical settings, system hardening, and device configuration.
Examples	SOC 2, HITRUST, ISO 27001	CIS Benchmarks, <u>Microsoft Baselines</u> , NIST SP 800-53 (H,M,L)
Audience	Executives, auditors, and governance teams.	System administrators, engineers, SOC.





A Structured Approach

Governance	Understand your place in the world? How do you want to govern security? How does it fit in with your business?
Risk Framing	Understand your industry requirements and specific threat profile. What techniques are adversaries using against organizations like you. What is the downside of a breach?
Technical Security	Select your baseline Customize your baseline to fit your org. What best enables your organization? Make tradeoff decision (how much friction are you willing to accept)? Add Administrative Controls
Compliance	Select your compliance framework An API for Trust



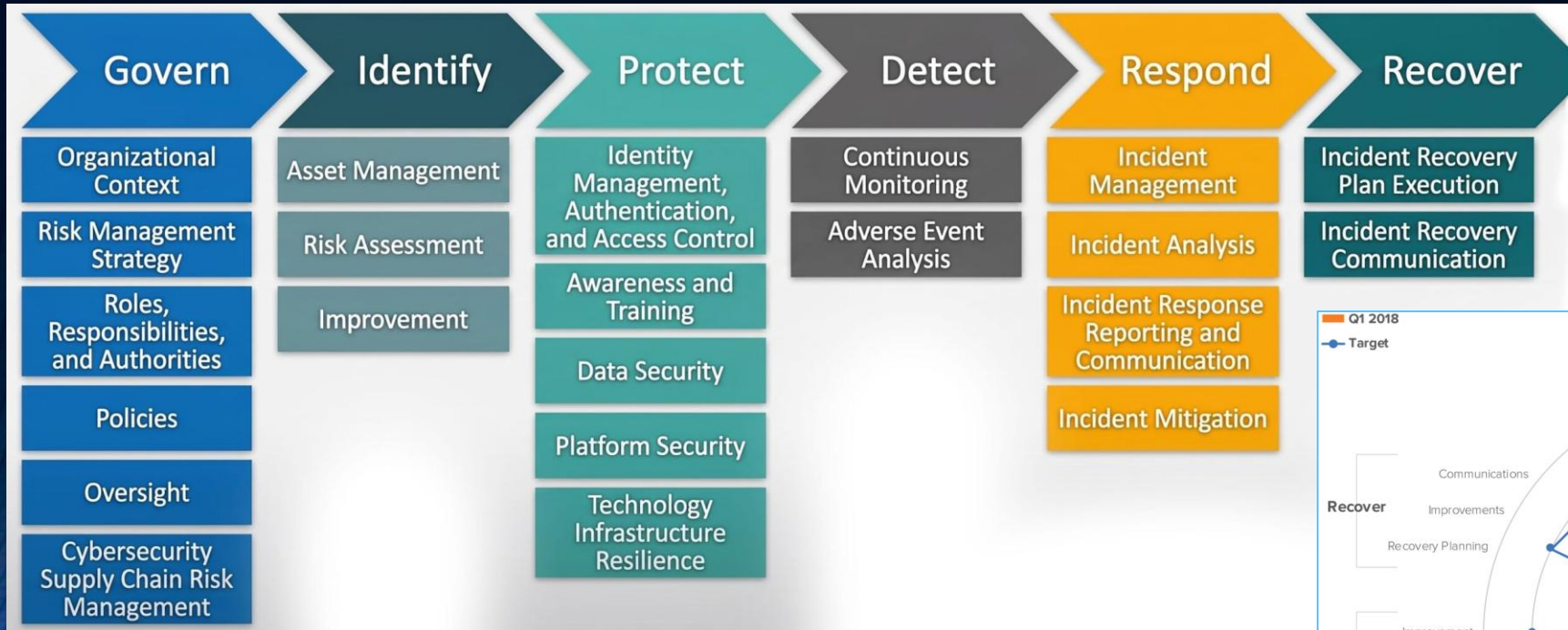
Risk Framing

Before you think about the IT think about the organization and its place in the world

Constraints/Restrains	THREATS	IMPACTS
<u>Regulatory</u> Laws And Regulations <u>Industry Standards</u> Rules That Govern Your Industry (E.G. Legal) <u>Customer Requirements</u> How You Serve Your Customer And Their Security Mandates <u>Industry Threat Profile</u> What Threat Actors Target Your Industry & Their TTP <u>Organization Policy</u> What Your Company Requires/Disallows	<u>Industry Threat Profile</u> What threat Actors are focused on your industry? <u>Threat Actor Profile</u> How do threat actors that target your industry conduct attacks? <u>ATT&CK</u> What Tactics, Techniques, Sub-Techniques does the adversary use? What detections and mitigations should you have in place?	<u>Technical</u> Vulnerability Exploits, Identity <u>Data</u> S3 Bucket Exposure <u>Regulatory</u> Privacy, Regulation Sanction <u>Contractual</u> Data Segregation <u>Human</u> Social Engineering Blast Radius <u>AI</u> Rogue Agent Blast Radius <u>Physical</u> Crime, Physical Data Center Breach



NIST Cybersecurity Framework





Leading With Technical Foundation



Foundational Elements of Security Implementation:

- **Hardened Infrastructure:** The right security controls for your environment
 - **Logical/Technical Controls:** Software-based settings, configurations, and controls (e.g. Secure Server Images, Authentication/MFA, Encryption, etc.)
 - **Administrative Controls:** Policies, and procedures. (e.g. Security Directive, Authentication Policy, Acceptable use, Data Classification & Management, etc.)
 - **Physical Controls:** measures to limit access to sensitive infrastructure like data centers (e.g. Locks, Fences, and Entry Control Procedures.)
- **Zero-trust Networking:** Authenticate Everything. Systems never trust, always verify
- **Defense-in-depth Engineering:** Integrate Security from the beginning into architecture design.



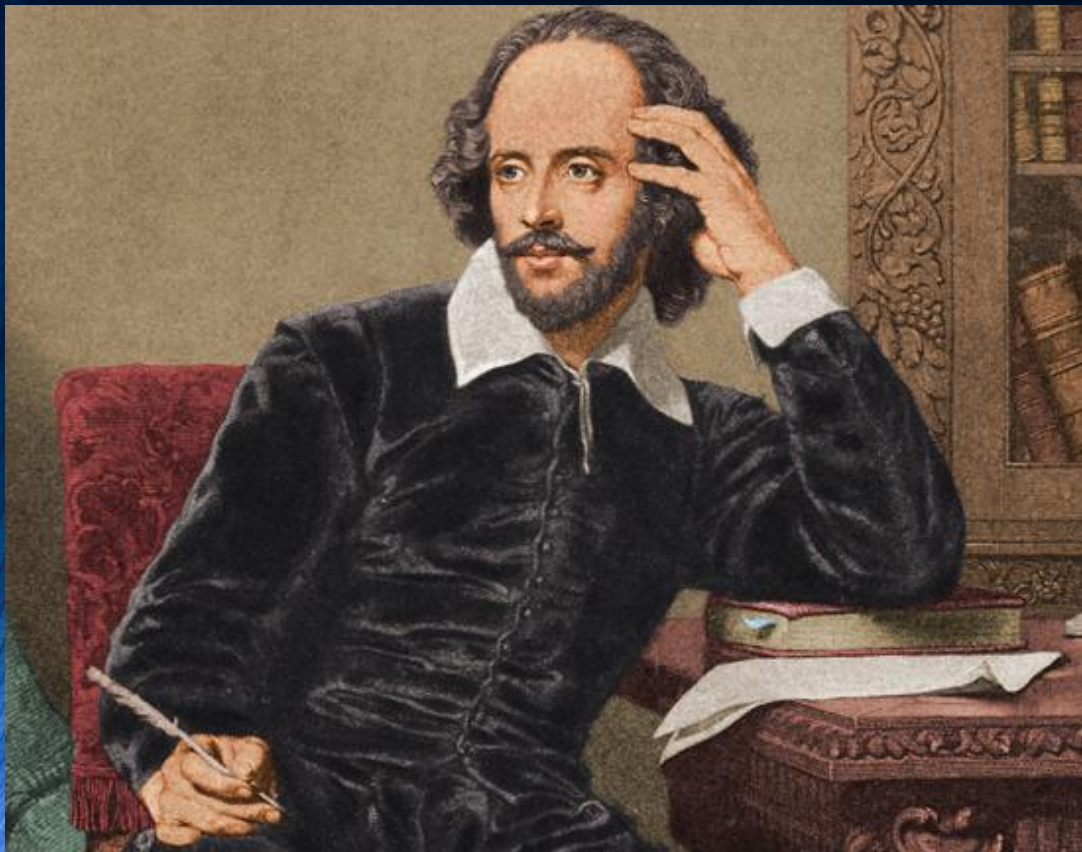
Leading with Technical Security



Security Baseline	Baseline	Pro	Con
Standard set of <u>security settings, configuration, and controls</u> established for each type of computer or network component that helps in reducing vulnerabilities, thus <u>lowering the risk of security incident</u>	Microsoft Security Baselines (Windows, M365, etc.)	• Integrated across Microsoft ecosystem	• Technically Oriented • Few Admin Controls
Configure your devices, servers, cloud, and security assets	CIS (Implementation Groups 1-3, Benchmarks)	• Org and Product • Extensive product benchmarks	• Membership requirements for Build Kits, OSCAL, etc.
Technical settings, system hardening, and device configuration.	NIST (High, Med, Low)	• Most comprehensive • All opensource (E.G. OSCAL) • Easily maps	• Operating System neutral/Integration work • No product benchmarks
CIS Benchmarks, <u>Microsoft Baselines</u> , NIST SP 800-53 (H,M,L)			
System administrators, engineers, SOC.			



Policies



PERSONNEL SECURITY POLICY

Process

Level 2 Policy Document

Document Version: 2.0

Effective Date: [Date]

Review Frequency: Annual

Policy Owner: Human Resources Director

Classification: Controlled Unclassified Information (CUI)

PURPOSE AND SCOPE

This Personnel Security Policy establishes standards and guidance for screening individuals

SECTION 1: SCREEN INDIVIDUALS [PS-01]

[Tag: PS.L2-3.9.1 / NIST 3.9.1]

Owner: Human Resources Director

Objective: Individuals are screened prior to authorizing access to organizational systems containing CUI to ensure trustworthiness, conduct, integrity, judgment, loyalty, reliability, and stability appropriate for their assigned position.

Policy Requirements:

1. Conduct background investigations for all positions prior to requesting system authorization in accordance with 3.1.1 Process 1: User/Administrative Account Authorization (Joiner/Mover/Leaver)

3.9.1 Process 1:
Onboarding/Reassignment/Off
boarding Process

SECTION 2: PERSONNEL ACTIONS [PS-02]

[Tag: PS.L2-3.9.2 / NIST 3.9.2]

Owner: Human Resources Director

Objective: Organizational systems containing CUI are protected during and after personnel actions such as terminations and transfers through timely access revocation and proper accountability measures.

Policy Requirements:

1. Automatically disable all system access within 12 hours of departing employees last day
2. Automatically disable all system access within 1 hour of termination notification
3. All personnel reassignment include update to role and groups

3.9.1 Process 1:
Onboarding/Reassignment/Off
boarding Process

Last Reviewed: [Date]

Next Review: [Date + 1 Year]

Approved By: [Name], Chief Information Security Officer



Defense in Depth Example

Attack Surface Management

- **Internet Facing:** Limit internet accessible infrastructure and access points
- **Vulnerability Management:** Prioritize patching based on how easily and adversary can reach the vulnerability.

Priority	Tier 1	Tier 2	Tier 3	Tier 4
Asset Type	Internet Facing	Internet Interaction	Internally Open	Segmented
Attack Surface Examples	Web Servers, VDI, VPN, Cloud Security, Cloud Surfaces	Laptops, Workstations, Tablets	On Prem Applications	Isolated Servers



Processes

NIST Definition

"A set of interrelated or interacting activities that use inputs to deliver an intended result.

Working Definition

The people, activities, and technology required to achieve a security outcome or meet an internal or external requirement

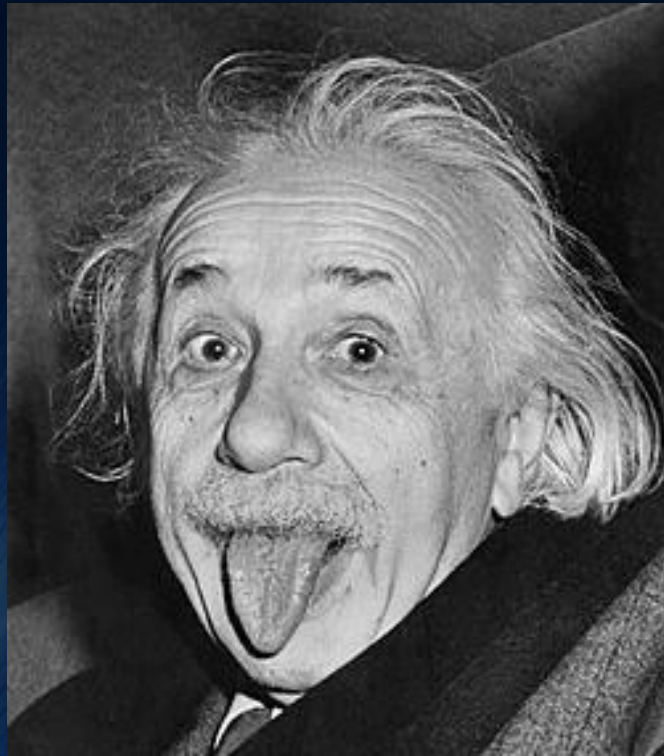


Processes Are How You Manage Complexity



Processes: CMMC Example

"If you can't explain it simply, you don't understand it well enough."



Use Processes to reflect what you actually do

PS-01: Onboarding, Reassignment, and Offboarding Process

[Tag: PS.L2-3.9.1 / PS.L2-3.9.2 / NIST 3.9.1-3.9.2]

PEOPLE

Primary Owner: Human Resources Director

Backup: Benefits Director

Executor: HR Staff

Audit Oversight: Security Auditor

PROCESS STATEMENT

Individuals are properly screened prior to be containing **Controlled Unclassified Informa**

Activity

Section 1: Onboarding (Joiner)

Screening:

Conduct background investigations prior to systems containing CUI.

Verify trustworthiness, integrity, judgment, assigned position.

System Authorization:

HR initiates onboarding workflow in **Micros** decision.

IT Security uses **Entra ID** to provision accou the **Roles Matrix**.

Devices are enrolled in **Microsoft Intune** fo

Audit Requirements:

Monthly reports of screening completions a

Quarterly review of screening criteria and v

Permanent retention of background investig

Section 3: Offboarding (Leaver)

Access Revocation:

Automatically disable all system access within **12 hours of last day**.

For involuntary terminations, disable access within **1 hour of notification**.

Asset Recovery:

Collect all company devices, badges, and physical access credentials.

Verify return of CUI media and secure destruction if necessary.

Exit Procedures:

Conduct exit interview to confirm awareness of confidentiality obligations.

Document asset return and access revocation in SharePoint workflow.

Audit Requirements:

Daily personnel action reports showing access revocation timing and asset recovery status.

Monthly compliance analysis and process improvement recommendations.

Retain offboarding documentation (exit interview records, asset return confirmations) for **90 days** minimum.

Technology Section

Microsoft Entra ID (Azure AD):

Identity and access management.

Role-based access control (RBAC).

Conditional Access enforcement.

Account provisioning and deprovisioning.

Microsoft 365 SharePoint Workflows:

Automated coordination of HR, IT Security, and data owners during personnel actions.

Documentation of onboarding, reassignment, and offboarding steps.



Processes: CMMC Example

- 27 Processes
- Vs
- 14 Domains
- 110 Requirements
- 320 Requirement objectives

Processes	
1	3.1.1 Process 1: User/Administrative Account Authorization (Joiner/Mover/Leaver)
2	3.1.1 Process 2: Process/Service Account Management
3	3.1.1 Process 3: Device Authorization and Management
4	3.1.1 Process 4: Roles Matrix
5	3.1.3 Process 1: Data Classification Standard
6	3.5.2 Process 1: Account Authentication Standard
7	3.1.9 Process 1: CUI Privacy & Security Notice Implementation
8	3.6.1 Process 1: Incident Response Plan
9	3.13.11 Process 1: Encryption Standard and Management
10	3.1.18 Process 1: Mobile Device Management and CUI Protection Implementation
11	3.13.1 Process 1: Tenant Boundary Definition and Enforcement
12	3.1.21 Process 1: Default Portable Storage Prohibition and Exception Process
13	3.1.22 Process 1: Public Information Control and CUI Protection
14	3.2.1 Process 1: Role Based Security Awareness and Training
15	3.11.1 Process 1: Risk Assessment Process
16	3.4.1 Process 1: Configuration Baseline and Security Enforcement
17	3.4.1 Process 2: Hardware and Software Inventory Management
18	3.4.3 Process 1: Configuration Control Process
19	3.4.6 Process 1: Block List and Application Control Implementation
20	3.4.9 Process 1: User Software Installation Prevention and Endpoint Control
21	3.7.1 Process 1: Maintenance and Vulnerability Management Process
22	3.8.3 Process 1: Media Sanitization and Data Destruction Process
23	3.8.9 Process 1: Backup Process
24	3.9.1 Process 1: Onboarding/Reassignment/Offboarding Process
25	3.10.1 Process 1: Physical Security Standard
26	3.12.4 Process 1: System Security Plan
27	3.14.2 Process 1: Malicious Code Protection



Frameworks: An API for Trust and Competitiveness



	Security Compliance Framework
Definition	Structured <u>system of policies, procedures, controls, and documentation</u> that helps organizations meet legal, regulatory, and industry-specific standards while <u>managing operational and reputational risks</u>
Primary Purpose	Manage risk and satisfy auditors/regulators
Focus	Process, policies, and overarching risk management.
Examples	SOC 2, HITRUST, ISO 27001
Audience	Executives, auditors, and governance teams.

Framework	What	Who
SOC 2	Select controls that meet • Security • Availability • Processing • Confidentiality • Privacy	B2B technology companies(SaaS provider, MSP, etc) that stores, processes, or transmits sensitive customer data
ISO 27001	Defined controls that • Identify Risk • Implement Controls • Improve	Companies that process sensitive data or are global



Operational Procedures As Living Evidence

Structure your Procedures and Processes so they are your actual work flows and operating procedures.

When Automating workflows, include audit artifacts production. Examples include:

- Incident response workflows that document for incident identification, handling and closeout
- Change management create traceable evidence as a natural byproduct of approval
- Access reviews periodic reviews produce access report automatically
- Vulnerability management automation that logs scan → triage → remediate



If your processes are well-designed, evidence collection is minimal extra work



Automating Compliance

The Open Security Controls Assessment Language (OSCAL) is a machine-readable language that simplifies and standardizes information system security assessments through the exchange of information via automation.

Originally developed by the National Institutes of Standards and Technology in collaboration with FedRAMP and industry, OSCAL aims to improve the efficiency, timeliness, accuracy, and consistency of system security assessments.



The NIST GitHub maintains **OSCAL content** for:

[NIST SP 800-53 revision 5 catalog & NIST SP 800-53B baselines](#)

[CSF v2.0 catalog.](#)

[NIST SP 800-171 revision 3 catalog.](#)



A Structured Approach Continued

GOVERNANCE

Risk Framing

SECURITY CONTROLS/ BASELINES

PROCESSES

FRAMEWORKS

CUSTOMERS/ REGULATORS

Regulatory

Laws And Regulations You Must Comply With

Industry Standards

Rules Or Norms That Govern Your Industry (E.G. Legal Medical)

Customer Requirements

How You Serve Your Customer And Their Security Mandates

Industry Threat Profile

What Threat Actors Target Your Industry & Their Ttps

Organization Policy

What Your Company Requires/Does Not Allow

Technical

Software and Hardware configurations, settings and tools (E.G. Firewall, EDR), Technical Procedures

Administrative

Policies, Training, Acceptable Use, Least Privilege Guidelines, Incident Response Planning and Exercise, Etc.

Physical

Locks, fences, entry control, and guards.

NIST Definition

"A set of interrelated or interacting activities that use inputs to deliver an intended result.

Working Definition

The people, activities, and technology required to achieve a security outcome or meet an internal or external requirement

How You Manage Complexity

HITRUST Definition

"A Cybersecurity framework is not a product, it's a methodology. It's "a standard that outlines the processes, controls, and policies organizations can adopt to protect digital assets." Examples Include

NIST CSF
SOC 2
ISO 270001
CMMC
FedRAMP

HITRUST
SOX
SIG
SIG Lite

Dictionary Definition

Compliance: "Acting according to certain accepted standards"

Working Definition

Security Compliance: A method for communicating security activities to provide assurance to an internal or external party of meeting standards

An API For Trust



MICHAEL DARLING
MP@SOLSTICELLC.IO